

Mapeo de preguntas de la Encuesta STRIDE a requisitos normativos

Nota: Este mapeo es orientativo y deberá adaptarse al texto final de la transposición de NIS2 en España, así como a las versiones vigentes del ENS y marcos sectoriales.

ID pregunta	Bloque / categoría STRIDE	Descripción abreviada	NIS2 (ejemplos)	ENS (ejemplos)	Otros marcos relevantes
P-0-01	General	Sector de actividad	Art. 3 (ámbito)	—	DORA, AI Act, regulaciones sectoriales
P-0-03	General	Condición de entidad esencial/importante	Art. 3, 4	—	NIS2 guía nacional de transposición
P-G-01	Gobierno	Proceso formal de threat modeling	Art. 21.2 (gestión riesgos)	ORG.1, OP.1	NIST CSF “Identify”, ISO 27005
P-G-02	Gobierno	Frecuencia de threat modeling	Art. 21.2	OP.1, OP.2	NIS2 assessment checklists [web:31] [web:34]
P-G-03	Gobierno	Uso explícito de STRIDE	Art. 21.2	OP.2	OWASP Threat Modeling [web:8]
P-S-01	Spoofing	Cobertura de MFA en accesos críticos	Art. 21.2 (medidas técnicas)	PROT.1, PROT.2, OP.2	ENS guías de autenticación, NIST SP 800-63
P-S-02	Spoofing / Elev. Priv.	Protección de accesos privilegiados	Art. 21.2	PROT.1, PROT.4	PAM, Zero Trust, CIS Controls
P-S-03	Spoofing	Autenticación en APIs y M2M	Art. 21.2	PROT.1, PROT.2	API Security (OWASP API Top 10)
P-S-04	Spoofing	Métricas de intentos de suplantación	Art. 21.2	OP.3, OP.4	NIST CSF “Detect”
P-S-05	Spoofing	Identidad digital de máquinas / PKI	Art. 21.2	PROT.1, PROT.3	Certificación, guías PKI
P-T-01	Tampering	Integridad criptográfica de datos y logs	Art. 21.2	PROT.2, PROT.6, OP.1	ISO 27001 A.8, A.12
P-T-02	Tampering	Capacidad interna de modificar datos sin trazabilidad	Art. 21.2	ORG.4, PROT.4	Segregación de funciones

P-T-03	Tampering / OT	Integridad en dispositivos IoT/OT	Art. 21.2	PROT.3, PROT.7	NIS2 y directrices sectoriales OT
P-T-04	Tampering	Gestión de cambios de configuración	Art. 21.2	ORG.3, OP.1	ITIL, ISO 20000, ISO 27001 A.12
P-R-01	Repudiation	Cobertura de logging en sistemas críticos	Art. 21.2, 23 (incidentes)	OP.1, OP.2, OP.3	NIST CSF “Detect”, “Respond”
P-R-02	Repudiation	Logs inmutables y retención	Art. 21.2	OP.3, PROT.2	Requisitos probatorios, auditoría
P-R-03	Repudiation	Capacidad de reconstrucción de eventos	Art. 23 (notificación)	OP.3, OP.4	NIS2 incident reporting [web:31] [web:40]
P-R-04	Repudiation / IA	Trazabilidad en flujos con IA	Art. 21.2	OP.1, OP.3	AI Act, ISO/IEC 42001 [web:20]
P-I-01	Info. Disclosure	Inventario y clasificación de datos	Art. 21.2	ORG.2, PROT.1	RGPD, ISO 27701
P-I-02	Info. Disclosure	Cifrado en reposo	Art. 21.2	PROT.2	ENS recomendaciones de cifrado
P-I-03	Info. Disclosure	Cifrado en tránsito / TLS	Art. 21.2	PROT.2	Buenas prácticas TLS
P-I-04	Info. Disclosure / Terc.	Riesgo en integraciones con terceros y cloud	Art. 21.2, 23	ORG.4, PROT.1, PROT.5	NIS2 proveedor / cadena suministro [web:37]
P-I-05	Info. Disclosure / IA	Control de fugas en salidas de IA	Art. 21.2	PROT.2, OP.1	AI Act, ISO/IEC 42001
P-D-01	DoS	Medición de disponibilidad / SLA	Art. 21.2	OP.1, OP.5	Continuidad de negocio, DORA
P-D-02	DoS	Protección frente a DoS/DDoS	Art. 21.2	PROT.3, PROT.5	Mitigación DDoS, guías nacionales
P-D-03	DoS / Continuidad	Planes de continuidad y contingencia	Art. 21.2	ORG.3, OP.5	ISO 22301, DORA

P-D-04	DoS / Seguridad	Resiliencia de capacidades de seguridad (SOC, SIEM)	Art. 21.2	OP.3, OP.5	NIST CSF “Respond”, “Recover”
P-E-01	Elev. Privilege	Gestión de identidades privilegiadas (PAM)	Art. 21.2	PROT.1, PROT.4	Zero Trust, CIS Controls
P-E-02	Elev. Privilege	Principio de mínimo privilegio	Art. 21.2	PROT.4	Requisitos de acceso basado en rol
P-E-03	Elev. Privilege	Auditoría de permisos y cuentas privilegiadas	Art. 21.2	ORG.4, OP.3	Auditorías internas/externas
P-E-04	Elev. Privilege / Gob.	Segregación de funciones	Art. 21.2	ORG.3, PROT.4	Buen gobierno TI, marcos de control interno
P-M-01	Métricas	Cuadro de mando con indicadores STRIDE	Art. 21.2	ORG.1, OP.1	NIST CSF, frameworks de madurez
P-M-02	Métricas	Uso de métricas en decisiones	Art. 21.2	ORG.1	Gestión de riesgos basada en datos
P-M-03	Métricas / ROI	Evaluación del ROI de seguridad	Art. 21.2	ORG.1	Gestión de inversiones, directrices sectoriales
P-M-04	Métricas	Frecuencia de revisión de postura de seguridad	Art. 21.2	ORG.1, OP.1	Ciclos de mejora continua

(Los códigos P... se corresponden con las preguntas de la encuesta; pueden adaptarse en la implementación final.)